

them enough inputs to tune up the attack, or change their methods.

Packet crafting techniques

As seen above, the whole idea behind packet crafting is to try to simulate an attack, thus learning the behavior of various network devices in order to gain knowledge about the vulnerabilities. Crafting is typically used to invade into firewalls and intrusion detection devices, but can also be used to attack Web servers and other application gateways. Now let's discuss a few common packet crafting techniques.

Ping fragmentation: In this type, instead of a standard ICMP ping packet, a malformed ping packet is created with more than 65535 bytes, which is the maximum allowed in a packet. This results in the destination system responding with an echo reply, which also consumes a larger packet frame and thus eventually results in a denial of service attack. One technique also sets an ACK flag in the packet, confusing the destination service, while in another type of attack, instead of a larger frame, a variable number of bytes are sent to overwhelm the system.

Packet flag manipulation: As we discussed before, there are multiple fields in the TCP datagram. One of the fields contains flags or bits, which could be set programmatically. For example, a SYN flag can be set and the packet can be sent over the wire to a destination to establish a valid TCP communication. This would be a healthy way of initiating a TCP handshake; however, it can be exploited by sending a RST or FIN packet, which can confuse the destination system. Older firewalls are known to be susceptible to FIN attacks, because they cannot properly differentiate between a valid packet and a bogus FIN packet. In another variety, a malformed SYN-ACK packet or ACK packet can cause a similar effect.

Packet duplication: Here, hackers capture a series of packets and simply re-send it over the network. This causes confusion at the destination system, which assumes that the previous session was not properly answered or terminated. A typical example of this attack is when a duplicate ACK or FIN packet is sent without modifying any other content of the packet frame. This method is commonly used in a denial of service attack.

Protocol manipulation: This is mainly used to test firewall vulnerabilities. Here the TCP and UDP flags are both set in a packet to confuse the firewall rule set. If the firewall is one of the latest, it can identify such a packet as a malformed one and will simply drop it. However, for legacy firewalls, if there are multiple rules set to handle TCP and UDP packets, both rules get executed causing an erroneous effect, which can lead to

the firewall shutting down. Another way is to not set the TCP or UDP flag at all—this tricks the switch devices managed by Layer 3.

Half open packets: In this method, hackers initiate a connection with a target host using a SYN packet. The target sends Syn-ACK; however, the hackers do not respond to it, and instead create a spoofed packet by changing the source IP and sending another SYN packet. This process continues, till the target host exhausts its resources, thus becoming a denial of service victim.

Protecting FOSS systems

As mentioned earlier, the packet crafting attack is a tough one to tackle. Despite this, there are ways to protect FOSS networks. The simple and correct method is to use packet crafting tools themselves, to test the infrastructure. The first step is to understand the network, and create security testing scenarios to test critical security components such as firewalls, routers, IDS systems, etc. Tools such as Hping and TCPReplay could be used to fabricate packets and send them to gather statistics and logs. A packet sniffer and analyser such as Wireshark can be used for this purpose. Firewalls and IDS systems built on FOSS technology should be tested on Layer-2 through to Layer-7. Performing such tests at regular intervals and staying up-to-date with the intrusion detection vulnerability signatures is the appropriate way to be protected. To protect FOSS Web servers, the latest Layer-7 content filtering firewall that is capable of performing a state-ful packet inspection, and which is equipped to detect and shun a denial of service attack, should be implemented. Linux distros lack a strong built-in security module to fight against packet crafting attacks. Hence, a properly designed perimeter defence system should be deployed to protect the infrastructure.

Packet crafting is a good way to audit your network; however, it can be used by evil hackers to penetrate into a network, by exploiting vulnerabilities. Configure firewalls, switches and routers properly to prevent networks from crafting attacks. Packet crafting attacks typically can happen from outside the firm's local area network, which demands a carefully designed perimeter defence security system for network infrastructure. 

By: Prashant Phatak

The author has over 18 years of experience in the field of IT hardware, networking, Web technologies and IT security. Prashant is MCSE and MCDBA certified and is also a F5 load balancer expert. In the IT security world he is an ethical hacker and a Net-forensic specialist. Prashant runs his own firm called Valency Networks in India (www.valencynetworks.com) providing consultancy in IT security design, security audits, infrastructure technology and business process management. He can be reached at prashant@valencynetworks.com.